GENERAL CUSTOMS DIRECTORATE · INFORMATION SECURITY OFFICE

Customs IT Security & Data Residency Standard

Document code	**CITS-2026**
Version	3.1
Effective date	1 March 2026
Classification	Internal: may be shared with bidders

SAMPLE DOCUMENT. Fictional standard created to test procurement-evaluation software.

1. Purpose and scope

1.1 This standard protects the confidentiality, integrity and availability of customs data. It sets the minimum security controls for any information system that captures, stores, processes or transmits customs data.

1.2 It applies to all systems operated by or for the Directorate, including systems procured through tenders, supplied by vendors, hosted at port authority premises, and maintained remotely by suppliers. Tender documents may add requirements; they may not lower them.

1.3 Requirements are identified by a code (e.g. SEC-01) and a priority: Mandatory requirements must be met; Important requirements are expected and weigh heavily in evaluations; Desirable requirements are good practice.

2. Definitions

Term	Meaning
Customs data	Any data produced or used in customs control, including inspection images, metadata, risk scores, analyst annotations, logs and backups.
Directorate infrastructure	Data centres, networks and equipment owned or controlled by the Directorate or the port authority within the national territory.
SIEM	The Directorate's Security Information and Event Management platform.
Critical / high vulnerability	A vulnerability rated 9.0–10.0 / 7.0–8.9 on the CVSS v3.1 base score.

3. Data classification and residency

Customs data is classified CONFIDENTIAL – CUSTOMS by default.

3.1 **SEC-01** — All customs data (scan images, metadata, analyst annotations, logs and backups) shall be stored and processed only within the national territory. (Mandatory)

4. Hosting and connectivity

4.1 **SEC-02** — Systems shall run on Directorate infrastructure; no component may depend on a public cloud service for operation, licensing, telemetry or updates. (Mandatory)

4.2 Connections between systems and external networks pass through the Directorate's managed firewalls. Inbound connections from the internet are not permitted.

5. Identity and access management

5.1 **SEC-03** — Users shall authenticate through the Directorate's Active Directory over LDAPS, with role-based access control mapped to job functions. (Mandatory)

5.2 **SEC-04** — Multi-factor authentication is required for all administrative accounts and for any remote access. (Mandatory)

5.3 **SEC-05** — Local accounts shall enforce passwords of at least 12 characters and lock after 5 failed attempts; interactive sessions shall lock after 15 minutes of inactivity. (Important)

6. Logging and monitoring

6.1 **SEC-06** — Tamper-evident audit logs of all user and administrator actions shall be retained for 5 years and forwarded in real time to the Directorate's SIEM using syslog or CEF. (Mandatory)

6.2 Clocks of all components are synchronised with the Directorate's NTP servers so that events can be correlated.

7. Cryptography

7.1 **SEC-07** — Data shall be encrypted at rest with AES-256 and in transit with TLS 1.2 or higher, using certificates issued by the Directorate's PKI. (Mandatory)

8. Vulnerability and patch management

8.1 **SEC-08** — In addition to routine patch releases, critical vulnerabilities shall be remediated within 14 days and high-severity vulnerabilities within 30 days of disclosure, throughout warranty and maintenance. (Important)

8.2 **SEC-09** — An independent penetration test shall be performed before go-live; all critical and high findings shall be closed before acceptance. (Mandatory)

9. Backup and continuity

9.1 **SEC-11** — Backups shall be taken daily, encrypted, and stored on-premise at a second site, with a recovery point objective of 24 hours or better and a recovery time objective of 8 hours or better for image management platforms. (Important)

10. Supplier personnel and remote support

10.1 **SEC-10** — Vendor remote access is allowed only through the Directorate's VPN, approved per session, with the full session recorded. (Mandatory)

10.2 **SEC-12** — Vendor staff with administrative access shall pass the Directorate's security vetting and sign a confidentiality undertaking before access is granted. (Important)

SAMPLE · FICTIONAL

11. Secure development and documentation

11.1 **SEC-13** — A Software Bill of Materials (SBOM) shall be delivered for all supplied software and updated with every release. (Important)

11.2 **SEC-14** — Architecture, data-flow and hardening documentation shall be delivered before the Site Acceptance Test. (Desirable)

12. Compliance verification and exceptions

12.1 Compliance is verified during design review, Site Acceptance Test and the pre-go-live penetration test.

12.2 Exceptions require the written approval of the Director of Information Security, with a remediation date.

Annex: requirements register

Code	Requirement	Priority
SEC-01	All customs data (scan images, metadata, analyst annotations, logs and backups) shall be stored and processed only within the national territory.	Mandatory
SEC-02	Systems shall run on Directorate infrastructure; no component may depend on a public cloud service for operation, licensing, telemetry or updates.	Mandatory
SEC-03	Users shall authenticate through the Directorate's Active Directory over LDAPS, with role-based access control mapped to job functions.	Mandatory
SEC-04	Multi-factor authentication is required for all administrative accounts and for any remote access.	Mandatory
SEC-05	Local accounts shall enforce passwords of at least 12 characters and lock after 5 failed attempts; interactive sessions shall lock after 15 minutes of inactivity.	Important
SEC-06	Tamper-evident audit logs of all user and administrator actions shall be retained for 5 years and forwarded in real time to the Directorate's SIEM using syslog or CEF.	Mandatory
SEC-07	Data shall be encrypted at rest with AES-256 and in transit with TLS 1.2 or higher, using certificates issued by the Directorate's PKI.	Mandatory
SEC-08	In addition to routine patch releases, critical vulnerabilities shall be remediated within 14 days and high-severity vulnerabilities within 30 days of disclosure, throughout warranty and maintenance.	Important
SEC-09	An independent penetration test shall be performed before go-live; all critical and high findings shall be closed before acceptance.	Mandatory
SEC-10	Vendor remote access is allowed only through the Directorate's VPN, approved per session, with the full session recorded.	Mandatory
SEC-11	Backups shall be taken daily, encrypted, and stored on-premise at a second site, with a recovery point objective of 24 hours or better and a recovery time objective of 8 hours or better for image management platforms.	Important
SEC-12	Vendor staff with administrative access shall pass the Directorate's security vetting and sign a confidentiality undertaking before access is granted.	Important

SEC-13	A Software Bill of Materials (SBOM) shall be delivered for all supplied software and updated with every release.	Important
SEC-14	Architecture, data-flow and hardening documentation shall be delivered before the Site Acceptance Test.	Desirable

SAMPLE · FICTIONAL